피싱·악성 이메일 신고 가이드

문서번호	GW-SEC-071	시행일	2026.10.01
작성·관리	정보보안팀	문서판	1.0

1. 의심 징후 확인

1.1 대표 징후

급한 결제·계정 정지·비밀번호 입력 요구, 실제 도메인과 비슷한 발신주소, 예상하지 못한 압축파일·매크로 문서, 외부 웹페이지의 로그인 재요청은 추가 확인이 필요하다.

1.2 정상 메일과 구분

회사 시스템의 알림과 유사한 양식도 위조될 수 있다. 발신자 표시이름만 보지 말고 공식 업무시스템의 안내와 접수번호를 직접 확인한다.

1.3 하지 말아야 할 일

의심 링크를 확인 목적으로 눌러보거나 첨부파일을 열지 않는다. 동료에게 원본을 무분별하게 전달하거나 신고 전 메일을 임의 삭제하지 않는다.

2. 신고 절차

2.1 열기 전 신고

사내 메일의 [보안 신고] 기능을 이용하거나 정보보안팀 지정 채널로 메일 제목·수신시각·발신주소·의심 사유를 신고한다. 원본 메일 헤더가 필요하면 담당자의 지시를 따른다.

2.2 링크 클릭 또는 입력

이미 링크를 열거나 계정정보를 입력했다면 즉시 추가 사용을 중단하고 신고한다. 발생 시각, 입력한 정보의 유형, 다운로드 또는 실행 여부를 솔직하게 전달한다.

2.3 담당자 조치

정보보안팀은 악성 여부를 판단하고 차단·계정 보호·추가 탐지를 지시한다. 계정 비밀번호 변경·단말 격리는 IT지원팀과 협의하여 증거를 보존하는 방법으로 실행한다.

3. 신고 이후

3.1 안내 확인

신고자는 접수번호와 추가 지시를 확인하고, 자체 판단으로 악성 파일을 사내 여러 기기에 재현하지 않는다.

3.2 잘못 신고한 경우

정상 메일을 신고한 것으로 확인되더라도 신고 사실 자체를 문제 삼지 않는다. 위협 여부를 분류하는 것은 담당팀의 역할이다.

업무 처리 기준 및 확인 사항

표 1. 상황별 즉시 대응

상황	직원 행동	담당자
의심 메일만 수신	링크·첨부 열지 않고 신고	정보보안팀
계정정보를 입력함	추가 입력 중단·즉시 신고	정보보안팀 / IT지원팀
첨부파일 실행함	작업 중지·담당자 지시 대기	정보보안팀
동료에게 전파됨	대상과 시각을 보고	정보보안팀